SYSTEM AND INFORMATION INTEGRITY

WyIT - 3012

PURPOSE: Ensure that IT resources and information systems are established with system integrity monitoring to include areas of concern such as malware, application and source code flaws, industry supplied alerts and remediation of detected or disclosed integrity issues.

I. APPLICABILITY

This policy applies to all Executive Branch agencies, boards, and commissions staff (collectively referred to as "agencies"). This policy is also applicable to consultants, affiliates, and temporary employees.

II. DEFINITIONS

All definitions for this policy are located in the Policy Dictionary.

III. EXCEPTIONS

Any exceptions provided to the following policy must abide by WyIT - 3002 - Security Exception Request policy.

IV. FLAW REMEDIATION

All applicable agencies, affiliates, and information system owners identified in the scope of this policy shall:

- Identify, report, and correct information system flaws.
- Test software and firmware updates related to flaw remediation for effectiveness and potential side effects before installation.

- Install security-relevant software and/or firmware updates within the timeframes listed:
  - Zero-Day Vulnerability: A vulnerability that is unknown to those interested in mitigating the vulnerability (including the vendor of the target software).
    - Critical System: Any system deemed essential for the organization's operations, including servers, databases, network infrastructure, and/or business-critical applications. Patches or mitigations must be applied within 24 hours of identification.
    - Non-Critical Systems: Patches or mitigations must be applied within 48 hours of identification.
  - Critical Vulnerabilities: Should be remediated within 15 calendar days of detection or within 15 calendar days of the release date of the relevant security patch.
  - High Vulnerabilities: Should be remediated within 30 calendar days of detection or within 30 calendar days of the release date of the relevant security patch.
  - Medium Vulnerabilities: Should be remediated within 60 of detection or within 60 calendar days of the release date of the relevant security patch.
  - Low Vulnerabilities: Should be remediated within 90 days of detection or within 90 calendar days of the release date of the relevant security patch.
  - Any vulnerability that cannot be remediated within the prescribed time frame, agencies, affiliates, and information system owners are required to abide by WyIT - 3002 - Security Exception Request policy and submit the required Security Exception Request.
- Incorporate flaw remediation into the configuration management process.
- Employ automated mechanisms to determine the state of information system components with regard to flaw remediation.

V. MALICIOUS CODE PROTECTION

All applicable agencies, affiliates, and information system owners identified in the scope of this policy shall:

- Employ malicious code protection mechanisms at information system entry and exit points to detect and eradicate malicious code.
- Update malicious code protection mechanisms whenever new releases are available in accordance with configuration management policy and procedures.

- Employ vulnerability scans upon any significant code change or annually, whichever comes first.
- Configure malicious code protection mechanisms to:
  - Computer systems must maintain network connectivity to ensure protections are distributed.
  - Real-time scans of files written or executed from any sources at the endpoint; network entry/exit points as the files are downloaded, opened, or executed in accordance with the security policy.
  - Block malicious code, quarantine malicious code, and send alerts to administrators, in response to malicious code detection.
- Address the receipt of false positives during malicious code detection and eradication and the resulting potential impact on the availability of the information system.

VI. INFORMATION SYSTEM MONITORING

All applicable agencies, affiliates, and information system owners identified in the scope of this policy shall:

- Monitor the information system to detect:
  - Attacks and indicators of potential attacks.
  - Unauthorized local, network, and remote connections.
- Identify unauthorized use of the information system through defined techniques and methods.
- Deploy monitoring devices strategically within the information system to collect system data indicating anomalous behavior(s) and at ad hoc locations within the system to track specific types of transactions of interest to the affiliate.
- Protect information obtained from intrusion-monitoring tools from unauthorized access, modification, and deletion.
- Heighten the level of information system monitoring activity whenever there is an indication of increased risk to operations and assets, individuals, other organizations, or based on law enforcement information, intelligence information, or other credible sources of information.
- Obtain legal opinion with regard to information system monitoring activities in accordance with applicable state and federal laws, directives, policies, or regulations.

- Provide information system monitoring information to authorized personnel or business units as needed.

VII. SYSTEM-GENERATED ALERTS

All applicable agencies, affiliates, and information system owners identified in the scope of this policy shall do the following:

- The information system data that may be generated from a variety of sources, including, for example, audit records or inputs from malicious code protection mechanisms, intrusion detection or prevention mechanisms, or boundary protection devices such as firewalls, gateways, and routers will be disseminated to authorized personnel or business units that shall take appropriate action on the alert(s).
- Alerts will be transmitted telephonically, by electronic mail messages, or by text messaging as required. Personnel on the notification list can include system administrators, mission/business owners, system owners, or information system security officers.

VIII. SECURITY ALERTS, ADVISORIES, AND DIRECTIVES

All applicable agencies, affiliates, and information system owners identified in the scope of this policy shall:

- Receive information system security alerts, advisories, and directives from approved open source and pay for services on an ongoing basis.
- Generate internal security alerts, advisories, and directives as deemed necessary.
- Disseminate security alerts, advisories, and directives to affiliates that have a valid need to know.
- Implement security directives in accordance with established time frames, or notify the issuing organization of the degree of noncompliance.

IX. SOFTWARE, FIRMWARE, AND INFORMATION INTEGRITY

All applicable agencies, affiliates, and information system owners identified in the scope of this policy shall:

- Employ integrity verification tools to detect unauthorized changes.

- Ensure the information system performs an integrity check at startup, and/or at security-relevant events.
- Incorporate the detection of unauthorized security-relevant changes to the information system into the incident response capability.

X. SPAM PROTECTION

All applicable agencies, affiliates, and information system owners identified in the scope of this policy shall:

- Employ spam protection mechanisms at information system entry and exit points to detect and take action on unsolicited messages.
- Update spam protection mechanisms when new releases are available in accordance with the configuration management policy and procedures.
- Manage spam protection mechanisms centrally.
- Ensure information systems automatically update spam protection mechanisms.

XI. INFORMATION INPUT VALIDATION

All applicable agencies, affiliates, and information system owners identified in the scope of this policy shall:

- Ensure the information system:
  - Checks the validity of affiliate defined information inputs.
  - Provides a manual override capability for input validation of affiliate defined inputs.
  - Restricts the use of the manual override capability to only affiliate defined authorized individuals.
  - Audits the use of the manual override capability.
  - Review and resolve within input validation errors.
  - Behaves in a predictable and documented manner that reflects system objectives when invalid inputs are received.

XII. ERROR HANDLING

All applicable agencies, affiliates, and information system owners identified in the scope of this policy shall:

- Systems shall:

- Have the ability to produce log files.
- Generate error messages that provide information necessary for corrective actions. Generated log files should include:
  - Timestamp of the error event
  - Error severity level
  - Detailed error message
  - System component where the error occurred
  - Additional contextual information relevant to the error
- Should provide a mechanism for notifying administrators when critical errors are logged.
- Must ensure that sensitive information within log files is appropriately protected.
- Publicly accessible information systems must implement measures to prevent the exposure of sensitive data. This sensitive information encompasses, but is not restricted to:
  - Error messages
  - IP address(s)
  - Site path
  - Internal contact information
- Must be easily readable and parsable by both humans and automated tools.

XIII. INFORMATION HANDLING AND RETENTION

All applicable agencies, affiliates, and information system owners identified in the scope of this policy shall:

- Handle and retain information within the information system and information output from the system in accordance with applicable state and federal laws, directives, policies, regulations, standards, and operational requirements.

XIV. MEMORY PROTECTION

All applicable agencies, affiliates, and information system owners identified in the scope of this policy shall:

- Ensure the information system implements affiliate defined security safeguards to protect its memory from unauthorized code execution.

REFERENCES: This policy has no supporting references to websites, other policies, federal or state statutes.

DOCUMENT HISTORY

ORIGINAL SUBMISSION				
SUBMITTED ON	**SUBMITTED BY**	**APPROVED BY**	**APPROVED BY DATE(S)**	**EFFECTIVE DATE**
July 2024	ETS Governance, Risk and Compliance	Public Comment Period	07/26/2024 - 08/09/2024	August 2024

REVISIONS		
LAST REVISION DATE	**LAST REVISED BY**	**LAST APPROVED BY**

REVIEWS		
LAST REVIEW DATE	**LAST REVIEWED BY**	**NEXT REVIEW DATE**